



Tertiary Infotech Pte Ltd

UEN: 20120096W

LEARNER GUIDE

For

AI Security for Autonomous AI Agents

TGS Ref No: TGS-2025060473

Conducted by

Tertiary Infotech Pte Ltd

UEN: 20120096W

Version 3.0

Document Version Control Record

DOCUMENT VERSION CONTROL RECORD

Version Number	Effective Date of Release	Summary of Included Changes	Author
1.0	16 June 2025	Initial release — Core Principles and Ethical Challenges in Generative AI.	Dr Alfred Ang
2.0	17 August 2026	Retitled and rebuilt for generative-AI and autonomous-agent security; five activities and detailed walkthroughs added. TSC K/A text unchanged.	Dr Alfred Ang
2.1	18 August 2026	Added prompt-injection practice, PDPA guidance, guardrails, human approval, skill/plugin controls and visual teaching aids. TSC K/A text unchanged.	Dr Alfred Ang
3.0	20 August 2026	Aligned to the evidence-grounded 207-slide deck; added product boundaries, documented cases, control gates, detailed activities and source register. Unverified claims removed. TSC K/A text unchanged.	Dr Alfred Ang

Table of Contents

Generated section contents for this v3.0 build.

Section	Page
About This Course	4
How to Use This Evidence-Grounded Guide	5
Day 1 — From AI Models to Acting Systems	9
Day 2 — Attack, Defend, Govern, Operate	50
Detailed Activity Walkthroughs	101
Operational Best-Practice Checklist	107
Source Register	108

About This Course

AI Security for Autonomous AI Agents is a 2 Days · 16 Hours WSQ course covering the security of generative AI systems and of autonomous AI agents. It is delivered through real-world case studies and grounded in the current security and governance frameworks.

This guide follows the course structure. Each section names the accredited knowledge (K) or ability (A) statement it evidences, and every activity has a full step-by-step walkthrough.

Learning Outcomes

LO	Learning Outcome
LO1	Demonstrate generative AI concepts and applications relevant to customer service and hospitality management.
LO2	Apply prompt engineering techniques and analyse output variations to improve generative AI performance in service settings.
LO3	Identify ethical risks and analyse bias in AI-generated content used in customer engagement.

Knowledge Statements

Code	Knowledge statement
K1	Importance of data quality, preprocessing, model pipeline and model training (e.g., impact of data bias from training data)
K2	Underlying principles, core concepts and theories governing generative AI
K3	Difference between generative and discriminative models
K4	Impact of prompt engineering on the model outputs of generative AI
K5	Generative AI model workings, including training data, algorithms, and outputs

Ability Statements

Code	Ability statement
A1	Analyse limitations and potential biases in AI-generated content
A2	Identify the ethical implications and societal impact of AI-generated content
A3	Apply understanding of generative AI principles to use cases
A4	Demonstrate the use of generation AI in diverse applications (e.g., summarisation, inference, reasoning, transformation of content, augmentation of content)
A5	Analyse generative AI models' performance metrics and evaluate the influence of prompt variations

How to Use This Evidence-Grounded Guide

This guide follows the 207-slide trainer deck in sequence. It expands the concepts, evidence status and control logic while keeping click-by-click procedures in the five activity walkthroughs. Product capabilities are always configuration- and version-specific.

Evidence label	Meaning	How to use it
HIST / DEF / PROD	Historical, definitional or product documentation	Cite the listed source and check the as-of date.
CASE-V	Verified incident, vulnerability or adjudicated case	State only what the primary or authoritative record supports.
CASE-R	Reported security research or campaign	Preserve the source's method, denominator and limitations.
SIM	Realistic synthetic classroom scenario	Treat every name, event and number as fictional.
SYN	Instructional synthesis	Use as a reasoning aid, not as a claimed empirical statistic.

EVIDENCE RULE

Never convert a demonstration into a breach, a simulation into a real incident, or a vendor statement into an independently verified outcome.

Slide 5 — Who Is in the Room?

EVIDENCE STATUS: ADMIN

Administrative or classroom-synthesis slide; no external factual claim is introduced.

Concept	Meaning or control implication
Role	What systems do you own or use?
Exposure	What data and tools can they reach?
Concern	What outcome would be hardest to reverse?

Slide 6 — Working Agreements for Security Labs

EVIDENCE STATUS: SYN

Administrative or classroom-synthesis slide; no external factual claim is introduced.

First view	Second view
Synthetic data only	No live credentials
Local dummy tools	No real recipients
Share evidence, not secrets	No production probing

Slide 7 — Why This Course Exists

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Model generates
2. Workflow iterates
3. Agent receives tools
4. Authority creates impact

CONTROL IMPLICATION

Security changes when probabilistic output can trigger actions in real systems.

Slide 8 — Two-Day Learning Journey

EVIDENCE STATUS: ADMIN

Administrative or classroom-synthesis slide; no external factual claim is introduced.

1. Evolution
2. System types
3. Attack surfaces
4. Cases
5. Controls
6. Governance

Slide 9 — Learning Outcomes

EVIDENCE STATUS: ADMIN

Administrative or classroom-synthesis slide; no external factual claim is introduced.

Concept	Meaning or control implication
LO1	Explain GenAI concepts and applications
LO2	Test prompt variations and controls
LO3	Analyse ethical, bias and security risks

Slide 10 — K1-K5 and A1-A5 Evidence Map

EVIDENCE STATUS: ADMIN

Administrative or classroom-synthesis slide; no external factual claim is introduced.

Evidence family	Statements	Where demonstrated
Models and data	K1–K3, K5	History, taxonomy, poisoning
Prompts and metrics	K4, A5	Injection activity
Use, limits, ethics	A1–A4	Cases and deployment gate

Slide 11 — Briefing for Assessment

EVIDENCE STATUS: ADMIN

Administrative or classroom-synthesis slide; no external factual claim is introduced.

1. Read the task
2. Use course evidence
3. State assumptions
4. Justify control choice
5. Submit on LMS

Slide 12 — Assessment Components and Boundaries

EVIDENCE STATUS: ADMIN

Administrative or classroom-synthesis slide; no external factual claim is introduced.

First view	Second view
Written Assessment	Case Study
Knowledge statements K1–K5	Learning outcomes and abilities
Open book	Evidence-based recommendation

Day 1 — From AI Models to Acting Systems

Origins → generation → agency → product anatomy → threat model

Slide 15 — The Dependency Map: What Must Be Understood First

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. What is the system?
2. What components does it add?
3. What authority does it receive?
4. What can fail?
5. What evidence controls it?

Slide 16 — Before 'Generative': What Did AI Mean?

EVIDENCE STATUS: DEF

Sources: S10 — NIST AI Risk Management Framework

Concept	Meaning or control implication
AI system	Engineered system producing predictions, recommendations, decisions or content
Objective	Outputs influence virtual or physical environments
Autonomy	Systems operate with varying levels of autonomy

Slide 17 — 1950 — The Machine-Intelligence Question

EVIDENCE STATUS: HIST

Sources: S01 — Turing, Computing Machinery and Intelligence (1950)

- Turing reframed the question through observable conversational behaviour
- The paper discussed learning machines as well as fixed programs
- It predates the term artificial intelligence

Slide 18 — 1955-1956 — 'Artificial Intelligence' Is Named

EVIDENCE STATUS: HIST

Sources: S02 — Dartmouth Summer Research Project on AI proposal, S03 — NIST, Reflections on Artificial Intelligence in Engineering

- The Dartmouth proposal used the term artificial intelligence
- The summer project took place in 1956
- The proposal treated learning and intelligence as problems that could be described precisely

Slide 19 — Symbolic AI and Early Learning Systems

EVIDENCE STATUS: HIST

Sources: S03 — NIST, Reflections on Artificial Intelligence in Engineering

First view	Second view
Symbolic systems	Learning systems
Represent knowledge as rules and symbols	Adjust behaviour from examples or feedback
Reason through explicit operations	Depend on data and objective design

Slide 20 — Cycles of AI Expectation and Investment

EVIDENCE STATUS: HIST

Sources: S03 — NIST, Reflections on Artificial Intelligence in Engineering

1. High expectations
2. Technical and funding limits
3. Reduced investment
4. Narrow commercial revival

CONTROL IMPLICATION

The history is cyclical; avoid a single-cause story for either progress or slowdown.

Slide 21 — Statistical Machine Learning — Course Synthesis

EVIDENCE STATUS: SYN

Administrative or classroom-synthesis slide; no external factual claim is introduced.

1. Collect examples
2. Represent features
3. Fit parameters
4. Evaluate on held-out data

CONTROL IMPLICATION

The decision boundary is learned from data rather than authored as a complete rule set.

Slide 22 — 2012 — Deep Learning's Visibility Breakthrough

EVIDENCE STATUS: HIST

Sources: S04 — Krizhevsky et al., ImageNet Classification with Deep CNNs

- AlexNet used a deep convolutional network for ImageNet classification
- The published system used GPUs to train the model
- Its result helped demonstrate the practical impact of deep learned representations

Slide 23 — Sequence Models and the Attention Problem

EVIDENCE STATUS: DEF

Sources: S05 — Vaswani et al., Attention Is All You Need

First view	Second view
Many earlier neural sequence models	Attention
Recurrence processes tokens in order	Weights relationships between positions
Long dependencies are difficult	Creates shorter paths between relevant tokens

Slide 24 — 2017 — The Transformer

EVIDENCE STATUS: HIST

Sources: S05 — Vaswani et al., Attention Is All You Need

1. Token representations
2. Self-attention
3. Feed-forward layers
4. Parallel training

CONTROL IMPLICATION

The original architecture dispensed with recurrence and convolution for its sequence-transduction tasks.

Slide 25 — From Large Models to Foundation Models

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile

Concept	Meaning or control implication
Pre-train	Learn broad patterns from large, diverse corpora
Adapt	Prompt, fine-tune or retrieve for a task
Reuse	One model supports many downstream applications

Slide 26 — 2020 — Few-Shot Behaviour at Scale

EVIDENCE STATUS: HIST

Sources: S06 — Brown et al., Language Models are Few-Shot Learners

- GPT-3 was evaluated on tasks described through text prompts
- Few-shot examples were provided in context rather than through task-specific gradient updates
- Performance varied substantially by task and prompt

Slide 27 — Instruction Following and Human Feedback

EVIDENCE STATUS: DEF

Sources: S07 — Ouyang et al., Training language models to follow instructions

1. Collect demonstrations
2. Train a reward model
3. Optimise against preferences
4. Evaluate helpfulness and safety

CONTROL IMPLICATION

Human feedback changes behaviour; it does not create a deterministic policy boundary.

Slide 28 — November 2022 — ChatGPT Broadens the Conversational Interface

EVIDENCE STATUS: HIST

Sources: S08 — Stanford AI Index Report 2023, S09 — NIST AI 600-1, Generative AI Profile

- ChatGPT's public release in November 2022 made multi-turn language-model interaction widely visible
- Natural-language prompts exposed many tasks through one interface
- A conversational interface did not remove limitations, variability or data risk

Slide 29 — Retrieval and Tool Use Move Beyond Chat

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026

1. Generate from model knowledge
2. Retrieve external context
3. Call structured tools
4. Iterate toward a goal

CONTROL IMPLICATION

Each step adds utility and a new trust boundary.

Slide 30 — The Evolution in One View

EVIDENCE STATUS: SYN

Sources: S01 — Turing, Computing Machinery and Intelligence (1950), S02 — Dartmouth Summer Research Project on AI proposal, S05 — Vaswani et al., Attention Is All You Need, S12 — OWASP Top 10 for Agentic Applications 2026

1. Reason with symbols
2. Learn patterns
3. Generate content
4. Retrieve and use tools
5. Plan and act

CONTROL IMPLICATION

This is an instructional synthesis, not a claim that one paradigm replaced every earlier one.

Slide 32 — A Taxonomy Warning: The Terms Are Not Standardised

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

- Sources use overlapping labels
- The course declares operational definitions
- Classify the architecture, not the marketing name

Slide 33 — Generative AI — Course Definition

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile

Concept	Meaning or control implication
Primary purpose	Generate synthetic text, image, audio, video or code
Interaction	Respond to supplied context and prompts
Boundary	A model response alone does not imply autonomous action

Slide 34 — How an Autoregressive Language Model Produces Text

EVIDENCE STATUS: DEF

Sources: S05 — Vaswani et al., Attention Is All You Need, S09 — NIST AI 600-1, Generative AI Profile

1. Tokenise context
2. Compute contextual representations
3. Estimate next-token probabilities
4. Decode the next-token sequence

CONTROL IMPLICATION

Sampling and context make output probabilistic rather than a fixed database lookup.

Slide 35 — Generative vs Discriminative Models — Course Comparison

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile

First view	Second view
Generative	Discriminative
Learns patterns used to produce new content	Learns to predict a class or score
May be exposed to injection, leakage, poisoning and unsafe output	May be exposed to poisoning, evasion, leakage and false positives

Slide 36 — Generative AI Strengths

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile

Concept	Meaning or control implication
Synthesis	Combine patterns into a new response
Transformation	Rewrite, translate or structure content
Interface	Express many tasks in natural language

Slide 37 — Generative AI Weaknesses

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile

Concept	Meaning or control implication
Confabulation	Fluent output can be unsupported or wrong
Variability	Prompt and sampling changes alter results
Provenance	Output may not reveal which source supported a claim

Slide 38 — Generative AI Security Exposure

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile, S11 — OWASP Top 10 for LLM Applications

Surface	Failure	Impact
Prompt/context	Instruction hijack	Wrong or disclosed output
Training/RAG	Poisoning	Biased or attacker-shaped answers
Output	Unsafe downstream handling	Code, data or browser impact

Slide 39 — Agentic AI — Course Definition

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Concept	Meaning or control implication
Goal-directed	Works toward an objective across steps
Iterative	Observes results and adjusts
System property	Agency comes from the model plus orchestration and authority

Slide 40 — The Plan-Act-Observe Loop

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

1. Interpret goal
2. Plan next step
3. Use tool or act
4. Observe result
5. Continue or stop

CONTROL IMPLICATION

A compromised objective can influence every later turn of the loop.

Slide 41 — Autonomy Is a Spectrum

EVIDENCE STATUS: DEF

Sources: S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Suggest
2. Prepare for approval
3. Act within hard bounds
4. Act broadly with monitoring

CONTROL IMPLICATION

Risk assessment should set autonomy by impact, reversibility, data sensitivity and tool reach.

Slide 42 — Agentic AI Strengths

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Concept	Meaning or control implication
Multi-step work	Decompose a goal into linked actions
Adaptation	Use observations to change the plan
Orchestration	Coordinate models, tools and specialised agents

Slide 43 — Agentic AI Weaknesses

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

Concept	Meaning or control implication
Compounding error	One mistake shapes later observations and plans
Runaway use	Loops consume time, tokens and tool capacity
Opaque sequence	A plausible final answer can hide a harmful path

Slide 44 — Agentic AI Security Exposure

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

Agentic property	Risk	Control direction
Goal pursuit	Goal hijack	Bind goal and stop conditions
Tool choice	Tool misuse	Allowlist and validate
Delegation	Cascade/inter-agent spoofing	Authenticate and limit fan-out

Slide 45 — AI Agent — Course Definition

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Concept	Meaning or control implication
Concrete system	A deployed software entity, not just a model
State and observation	Receives environment feedback and may retain context
Authority	Acts through tools, identities and policies

Slide 46 — The Agent as a Whole System

EVIDENCE STATUS: SYN

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

Concept	Meaning or control implication
Mind	Model, instructions and planning loop
State	Context, retrieval and memory
Hands	Tools, identity, runtime and network
Accountability	Owners, approvers, users and operators

Slide 47 — Instructions and Context

EVIDENCE STATUS: DEF

Sources: S11 — OWASP Top 10 for LLM Applications, S12 — OWASP Top 10 for Agentic Applications 2026

Concept	Meaning or control implication
Trusted intent	System policy and authorised user objective
Untrusted content	Files, mail, web, tool output and context files
Core weakness	Selected or retrieved sources can become model-readable context

Slide 48 — Retrieval and Memory

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026

Layer	Purpose	Security concern
Prompt context	Current turn	Injection and leakage
RAG corpus	External knowledge	Poisoning and access control
Persistent memory	Cross-session state	Durable manipulation and privacy

Slide 49 — Recommended Tool-Execution Path

EVIDENCE STATUS: SYN

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Model proposes intent
2. Policy checks identity
3. Schema constrains parameters
4. Tool executes
5. Result is logged

CONTROL IMPLICATION

The identity and policy layer—not model confidence—defines authority.

Slide 50 — Runtime, Network, and Feedback

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

Concept	Meaning or control implication
Runtime	Local host, container, VM or managed service
Network	Inbound channels and outbound destinations
Feedback	Tool results and environment state become new input

Slide 51 — AI-Agent Strengths

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

Concept	Meaning or control implication
Completion	Carry a task across applications
Optional persistence	Where configured, resume or schedule work over time
Specialisation	Delegate subtasks to tools or other agents

Slide 52 — AI-Agent Weaknesses

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Concept	Meaning or control implication
Blast radius	Compromise inherits delegated authority
Hidden state	Memory and intermediate actions complicate review
Responsibility	Multiple providers and operators can obscure ownership

Slide 53 — AI-Agent Security Exposure

EVIDENCE STATUS: DEF

Sources: S11 — OWASP Top 10 for LLM Applications, S12 — OWASP Top 10 for Agentic Applications 2026

Axis	Exposure	Potential effect
Content	Injection/jailbreak	Changed goal or output
Authority	Token/tool misuse	Unauthorised action
Runtime	Code/network/supply chain	Host impact or exfiltration
State	Memory poisoning	Persistent behaviour change

Slide 54 — Three Overlapping Operating Layers

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Dimension	Generative layer	Agentic pattern	Deployed agent
Primary role	Create content	Pursue goals iteratively	Operate as a concrete actor
State	Context-dependent	Loop state	May persist memory
Authority	None inherent	Configuration-dependent	Defined by tools and identity

CONTROL IMPLICATION

These layers can coexist in one product; they are not mutually exclusive species.

Slide 55 — Same Model, Different Risk

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026

First view	Second view
Chat configuration	Agent configuration
Reads one prompt	Reads external sources
Returns text	Loops and calls tools
Human executes any action	System executes within delegated authority

Slide 56 — Which Operating Layers Are Present?

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Does it mainly generate?
2. Does it iterate toward a goal?
3. Does it maintain state?
4. Can it call tools?
5. What authority is delegated?

CONTROL IMPLICATION

Classify observable architecture and permissions, not the product label.

Products Are Configurations, Not Risk Labels

Compare capability, deployment and authority—not brand reputation.

Slide 58 — Examples Across Three Overlapping Layers

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026

Operating layer	Example	Decisive property
Generative	Draft or summarise on request	Returns content
Agentic	Plan, retry and route tools	Iterates toward a goal
Deployed agent	OpenClaw or Hermes deployment	Concrete runtime with tools and identity

Slide 59 — Model vs Application vs Harness vs Agent

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026

1. Model generates or scores
2. Application supplies context
3. Harness orchestrates state/tools
4. Agent acts in an environment

CONTROL IMPLICATION

Model choice alone does not reveal filesystem, network or credential exposure.

Slide 60 — Four Common Deployment Patterns (May Overlap)

EVIDENCE STATUS: SYN

Sources: S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Deployment	Boundary	Primary review
Hosted SaaS	Provider plus tenant controls	Data terms and workspace settings
Local CLI/desktop	User account and host	Filesystem, shell and secrets
Self-hosted gateway	Organisation runtime	Network, identity and isolation
Embedded enterprise	Application and service accounts	API scopes and transaction controls

Slide 61 — OpenClaw — Documented Architecture

EVIDENCE STATUS: PROD

Sources: S17 — OpenClaw Gateway Security

Concept	Meaning or control implication
Gateway	Connects channels, sessions and tools
Host state	Configuration and credentials live under the runtime state directory
Trust model	Documentation assumes one trusted operator boundary per gateway

CONTROL IMPLICATION

As-of 20 Aug 2026; re-check before publication.

Slide 62 — OpenClaw — Documented Security Boundaries

EVIDENCE STATUS: PROD

Sources: S17 — OpenClaw Gateway Security

Boundary	Documented control	Residual concern
Senders	Allowlists and pairing	Within one trusted-operator boundary, allowed users share delegated authority
Gateway	Audit and scoped configuration	Operator credentials are sensitive
Tools	Deny high-risk tools for untrusted content	Node execution can affect a paired host

CONTROL IMPLICATION

As of 20 Aug 2026; controls depend on the gateway, channel, tools and host configuration.

Slide 63 — Hermes Agent — Documented Architecture

EVIDENCE STATUS: PROD

Sources: S18 — Hermes Agent documentation

Concept	Meaning or control implication
Entry points	CLI, gateway, API and library modes
State	Persistent memory, skills and project context
Authority	Built-in tools, MCP and multiple execution backends

CONTROL IMPLICATION

As-of 20 Aug 2026; re-check before publication.

Slide 64 — Hermes Agent — Documented Security Layers

EVIDENCE STATUS: PROD

Sources: S19 — Hermes Agent Security

Layer	Purpose	Example
Authorisation	Control who can interact	Allowlist and DM pairing
Execution	Constrain dangerous operations	Approval and container isolation
Context	Reduce malicious project instructions	Context-file scanning

CONTROL IMPLICATION

As of 20 Aug 2026; permanent approvals, permissive modes and execution backend alter exposure.

Slide 65 — Claude Code — Capability and Authority Profile

EVIDENCE STATUS: PROD

Sources: S20 — Anthropic — Claude Code sandboxing, S29 — Anthropic Model Context Protocol overview, S43 — Anthropic — Claude Code permission modes

Concept	Meaning or control implication
Local context	Reads project files within configured access
Tools	Terminal and MCP expand capability
Permissions	Allowed/disallowed tools and permission modes affect authority

CONTROL IMPLICATION

As of 20 Aug 2026; sandbox and permission mode are configuration-specific. A bypass flag is not a recommended default.

Slide 66 — Codex — Capability Depends on Surface and Mode

EVIDENCE STATUS: PROD

Sources: S21 — OpenAI — Codex sandboxing, S22 — OpenAI — agent approvals and security, S30 — OpenAI — Codex cloud internet access

Concept	Meaning or control implication
Workspace	Supported local configurations can bound writes to an authorised workspace
Approval	Access outside the boundary or consequential actions can require approval
Network	Cloud internet access is separately configurable and changes injection and exfiltration exposure

CONTROL IMPLICATION

As-of 20 Aug 2026; cite the exact deployed Codex surface and settings.

Slide 67 — ChatGPT Chat and ChatGPT Work — Current Surfaces

EVIDENCE STATUS: PROD

Sources: S22 — OpenAI — agent approvals and security, S28 — OpenAI — skills and plugins, S32 — OpenAI — ChatGPT Work overview

First view	Second view
Chat	Work
Conversational exploration and generation	Supports multi-step work with authorised files, apps and tools
Authority depends on enabled tools and context	Local/cloud surface, member permissions and admin policy define the boundary

CONTROL IMPLICATION

As of 20 Aug 2026; feature availability and authority depend on plan, workspace and enabled tools.

Slide 68 — DeepSeek Model vs DeepSeek Harness

EVIDENCE STATUS: PROD

Sources: S23 — DeepSeek-V3 official repository and model card, S36 — DeepSeek Harness — official developer-preview repository

Concept	Meaning or control implication
DeepSeek-V3 model	Model card describes weights and inference; it does not define host authority
DeepSeek Harness	Official repository labels dsh a developer preview with plugin-oriented architecture
Security decision	Treat production controls as unknown until the exact version and configuration are verified

CONTROL IMPLICATION

As of 20 Aug 2026; model and harness are different layers. Do not import permissions or sandbox claims from one to the other.

Slide 69 — Prime Agent and QM — Documented Boundaries

EVIDENCE STATUS: PROD

Sources: S34 — Prime Intellect — Prime Agent repository and launch documentation, S35 — QM — official repository and security policy, S45 — QM — official repository README

Concept	Meaning or control implication
Prime Agent	Persistent coding/research harness; its documentation says the kernel is not a security sandbox
QM	Early organisational-agent harness with durable sandboxes, memory, skills and documented security limitations
Deployment gate	Verify exact version, host, command posture, egress, credentials and external containment

CONTROL IMPLICATION

As of 20 Aug 2026; first-party documentation describes capabilities and limitations, not independent assurance or a safety ranking.

Slide 70 — Eight Products — Runtime and Review Focus

EVIDENCE STATUS: PROD

Sources: S17 — OpenClaw Gateway Security, S18 — Hermes Agent documentation, S20 — Anthropic — Claude Code sandboxing, S21 — OpenAI — Codex sandboxing, S22 — OpenAI — agent approvals and security, S32 — OpenAI — ChatGPT Work overview, S34 — Prime Intellect — Prime Agent repository and launch documentation, S35 — QM — official repository and security policy, S36 — DeepSeek Harness — official developer-preview repository, S45 — QM — official repository README

Product	Documented runtime emphasis	Primary review
OpenClaw	Self-hosted gateway, channels and tools	Trusted operator, host and tool policy
Hermes	CLI/gateway/API with selectable execution backends	Approvals, backend, memory and MCP
Prime Agent	Persistent Python, skills, subagents and schedules	External isolation and user OS permissions
QM	Organisational harness with durable scoped sandboxes	Permission mode, keys and egress
DeepSeek Harness	Developer-preview plugin harness	Exact commit, plugins, listener and host
Claude Code	Repository-aware coding agent	Sandbox, terminal/MCP and permission mode
Codex	Local and cloud surfaces	Workspace, approval and network mode
ChatGPT / Work	Chat plus authorised files/apps/tools	Local/cloud surface and admin policy

CONTROL IMPLICATION

As of 20 Aug 2026; documented capability is not a safety score.

Slide 71 — OpenClaw vs Hermes — Gateway and Execution

EVIDENCE STATUS: PROD

Sources: S17 — OpenClaw Gateway Security, S18 — Hermes Agent documentation, S19 — Hermes Agent Security

First view	Second view
OpenClaw	Hermes
One trusted-operator gateway boundary	CLI, gateway, API and library entry points
Channels, tools, nodes and runtime state	Memory, skills, MCP and multiple execution backends
Sandboxing and exposure depend on configuration	Approvals and backend choice change authority

CONTROL IMPLICATION

As of 20 Aug 2026; compare deployments, not brand names.

Slide 72 — Prime Agent vs QM — Persistence and Permission

EVIDENCE STATUS: PROD

Sources: S34 — Prime Intellect — Prime Agent repository and launch documentation, S35 — QM — official repository and security policy, S45 — QM — official repository README

First view	Second view
Prime Agent	QM
Persistent Python, subagents and schedules	Durable per-scope sandbox, memory and files
Model-generated Python and commands execute with the launching user's OS permissions	Strict, Auto and Dangerous permission modes
Kernel is not a security sandbox	Early software with documented limitations

CONTROL IMPLICATION

As of 20 Aug 2026; external containment and selected mode are part of the risk decision.

Slide 73 — DeepSeek Harness vs Claude Code — Plugin and Repository Boundary

EVIDENCE STATUS: PROD

Sources: S20 — Anthropic — Claude Code sandboxing, S29 — Anthropic Model Context Protocol overview, S36 — DeepSeek Harness — official developer-preview repository

First view	Second view
DeepSeek Harness (dsh)	Claude Code
Official developer preview	Repository-aware coding workflow
Plugin-oriented harness and local UI	Terminal and MCP capability
Production control baseline not verified	Sandbox and permission mode affect authority

CONTROL IMPLICATION

As of 20 Aug 2026; assess the exact version and enabled extensions.

Slide 74 — Codex vs ChatGPT Work — Workspace and Tool Authority

EVIDENCE STATUS: PROD

Sources: S21 — OpenAI — Codex sandboxing, S22 — OpenAI — agent approvals and security, S30 — OpenAI — Codex cloud internet access, S32 — OpenAI — ChatGPT Work overview

First view	Second view
Codex	ChatGPT Work
Local/cloud coding surfaces	Multi-step local/cloud work
Workspace sandbox and approvals vary by mode	Uses authorised files, apps and tools
Internet access is separately configurable	Member permissions and admin policy shape effects

CONTROL IMPLICATION

As of 20 Aug 2026; state the product surface and mode before comparing risk.

Slide 75 — Extension and Persistence Questions Across All Eight

EVIDENCE STATUS: SYN

Sources: S17 — OpenClaw Gateway Security, S18 — Hermes Agent documentation, S28 — OpenAI — skills and plugins, S29 — Anthropic Model Context Protocol overview, S34 — Prime Intellect — Prime Agent repository and launch documentation, S35 — QM — official repository and security policy, S36 — DeepSeek Harness — official developer-preview repository, S45 — QM — official repository README

Axis	What to verify	Why it matters
Skills/plugins/MCP	Publisher, code, instructions, scopes and update channel	Extensions can add data and action paths
Memory/schedules	Where supported, provenance, retention and revocation	State can outlive the initiating turn
Credentials	Identity, scope, lifetime and storage	Compromise inherits delegated authority
Network	Inbound triggers and outbound destinations	Reach defines trigger and exfiltration paths

CONTROL IMPLICATION

Not documented means unknown—not absent.

Slide 76 — Product Evidence Gate Before Deployment

EVIDENCE STATUS: SYN

Sources: S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Pin product/version
2. Name runtime and host
3. Inventory data/tools
4. Verify approval/logging
5. Record unknowns and re-test

CONTROL IMPLICATION

Re-check documentation at change or publication; no product receives a universal green/red score.

Slide 77 — Select by Use Case and Risk Tier

EVIDENCE STATUS: SYN

Sources: S10 — NIST AI Risk Management Framework, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Classify impact
2. Classify data
3. Identify actions
4. Assess reversibility
5. Choose bounded deployment

CONTROL IMPLICATION

A higher-capability product is acceptable only when its authority and evidence fit the risk.

Threat Modelling AI Systems

Follow content to authority, effect and evidence.

Slide 80 — Classical Security Still Applies

EVIDENCE STATUS: DEF

Sources: S10 — NIST AI Risk Management Framework, S13 — MITRE ATLAS

Concept	Meaning or control implication
Identity	Authenticate users, services and agents
Systems	Patch, segment and harden hosts
Operations	Log, detect, respond and recover

Slide 81 — What AI Adds or Amplifies

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile, S11 — OWASP Top 10 for LLM Applications, S12 — OWASP Top 10 for Agentic Applications 2026

First view	Second view
Conventional	AI-specific/amplified
Software vulnerabilities	Instruction/data confusion
Credential theft	Poisoned context and memory
Supply-chain compromise	Probabilistic plans driving tools

Slide 82 — Threat Actors and Their Access Paths

EVIDENCE STATUS: SYN

Sources: S13 — MITRE ATLAS

Concept	Meaning or control implication
External	Users, senders and web publishers
Internal	Staff, admins and data curators
Supply chain	Model, plugin, skill, MCP and package publishers

Slide 83 — Assets Worth Protecting

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026), S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

Concept	Meaning or control implication
Data	Personal data, prompts, files, memory and logs
Authority	Tokens, permissions, tools and approvals
Decisions	Outputs, actions, provenance and audit evidence

Slide 84 — Trust Boundaries in a GenAI Application

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile, S11 — OWASP Top 10 for LLM Applications

1. User/channel
2. Application
3. Model provider
4. Retrieval source
5. Output consumer

CONTROL IMPLICATION

Annotate who controls each boundary and which data crosses it.

Slide 85 — Trust Boundaries in an AI Agent

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

1. Untrusted content
2. Planner and memory
3. Policy/identity
4. Tool/runtime
5. Network/environment

CONTROL IMPLICATION

The agent adds persistent state and action paths to the model boundary.

Slide 86 — Treat Every Content Source as Untrusted

EVIDENCE STATUS: SYN

Sources: S11 — OWASP Top 10 for LLM Applications, S12 — OWASP Top 10 for Agentic Applications 2026, S17 — OpenClaw Gateway Security, S19 — Hermes Agent Security

Concept	Meaning or control implication
Human content	Prompts, email, chat and documents
Machine content	Web, APIs and tool output
Project content	Memory, context files, skills, plugins and MCP metadata

Slide 87 — Follow the Authority Path

EVIDENCE STATUS: SYN

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Attacker controls content
2. Model interprets
3. Planner selects action
4. Policy permits
5. Tool creates effect

CONTROL IMPLICATION

Break the path with deterministic controls as close to the effect as possible.

Slide 88 — Threat-Modelling Method

EVIDENCE STATUS: SYN

Sources: S10 — NIST AI Risk Management Framework, S13 — MITRE ATLAS, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Scope use case
2. Map data and components
3. Mark trust boundaries
4. Write abuse cases
5. Select and test controls

Slide 89 — Attack Surface by Operating Layer

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S11 — OWASP Top 10 for LLM Applications, S12 — OWASP Top 10 for Agentic Applications 2026

Surface	Generative	Agentic	Agent
Input	Prompt/context	Goal and observations	Channels, files, web
State	Context window	Loop state	RAG and persistent memory
Effect	Output	Plan/tool selection	Real system action

Slide 90 — A Complete Attack Chain

EVIDENCE STATUS: SYN

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S13 — MITRE ATLAS

1. Deliver
2. Interpret
3. Plan
4. Authorise
5. Execute
6. Persist
7. Impact

CONTROL IMPLICATION

Record evidence and a feasible control at every stage.

Slide 91 — Activity 1 — Concierge Threat Model

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Map three input channels, four retrieval sources and four tools
- Mark attacker-writable content and personal-data paths
- Recommend proceed, conditional proceed or halt

Slide 92 — Activity 1 — Build the Data-Flow Diagram

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Place channels and data owners on the left
- Put model, retrieval and memory in the centre
- Put tool actions and affected people on the right

Slide 93 — Activity 1 — Rank Trust Boundaries

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Who can write the source?
- What authority can follow from it?
- How reversible is the effect?

Slide 94 — Activity 1 — Design Abuse Cases

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- One GenAI content failure
- One agentic loop or goal failure
- One tool/identity action failure

Slide 95 — Activity 1 — Decide the Controls

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Rank controls by earliest break point
- State latency, cost and user-friction trade-offs
- Name evidence proving each control works

Slide 96 — Day 1 Integrated Risk Matrix

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S11 — OWASP Top 10 for LLM Applications, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

System	Primary exposure	Control direction
Generative	Content and disclosure	Constrain data access and downstream effect; validate before use
Agentic	Goal and loop	Stop conditions and budgets
Agent	Tools, identity, runtime	Least privilege, sandbox and approval

Slide 97 — Day 1 Recap — What Changed as AI Gained Agency?

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Concept	Meaning or control implication
Generate	Probability creates useful but fallible content
Iterate	Loops compound decisions and cost
Act	Tools and identity turn output into impact

Slide 98 — Day 2 Preview — From Attack to Assurance

EVIDENCE STATUS: ADMIN

Administrative or classroom-synthesis slide; no external factual claim is introduced.

1. Study attack mechanisms
2. Separate case evidence
3. Engineer hard controls
4. Govern and operate

Day 2 — Attack, Defend, Govern, Operate

Cases make the mechanisms concrete; controls then become testable evidence.

Slide 100 — Day 2 Dependency Map

EVIDENCE STATUS: SYN

Sources: S10 — NIST AI Risk Management Framework, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Observe attack
2. Trace authority
3. Identify impact
4. Place controls
5. Prove and govern

Prompt Injection and Jailbreaks

Distinguish changing application intent from bypassing model behaviour rules.

Slide 102 — Prompt Engineering vs Prompt Injection

EVIDENCE STATUS: DEF

Sources: S11 — OWASP Top 10 for LLM Applications

First view	Second view
Prompt engineering	Prompt injection
Authorised user shapes the requested output	Untrusted text changes instructions or data flow
Success serves the declared task	Success serves an attacker or unintended objective

Slide 103 — Direct Prompt Injection

EVIDENCE STATUS: DEF

Sources: S11 — OWASP Top 10 for LLM Applications

Concept	Meaning or control implication
Delivery	Attacker writes into the user-facing prompt
Conflict	Text asks the model to ignore or reinterpret policy
Control	Detect attempts and constrain downstream authority

Slide 104 — Indirect Prompt Injection

EVIDENCE STATUS: DEF

Sources: S11 — OWASP Top 10 for LLM Applications, S22 — OpenAI — agent approvals and security

Concept	Meaning or control implication
Delivery	Payload sits in email, file, page or other content
Trigger	A legitimate user asks the system to process it
Impact	Model may treat data as instructions

Slide 105 — Cross-Modal Prompt Injection

EVIDENCE STATUS: DEF

Sources: S11 — OWASP Top 10 for LLM Applications

Concept	Meaning or control implication
Carrier	Image, audio or mixed-media content
Recovery	OCR, vision or transcription exposes instruction text
Gap	A text-only filter may never inspect the carrier

Slide 106 — Retrieval-Augmented Injection

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile, S11 — OWASP Top 10 for LLM Applications

1. Attacker writes source
2. Indexer stores chunk
3. Retriever selects chunk
4. Model reads payload
5. Output/action is altered

CONTROL IMPLICATION

Secure both who may write the corpus and what authority follows retrieval.

Slide 107 — Email and Document Injection

EVIDENCE STATUS: SIM

Sources: S11 — OWASP Top 10 for LLM Applications

Concept	Meaning or control implication
Legitimate task	Summarise a supplier email or invoice
Hostile content	Quoted text requests data or a changed instruction
Boundary	Reader remains tool-free; sensitive actions use independent verification

Slide 108 — Web and Browser Injection

EVIDENCE STATUS: DEF

Sources: S11 — OWASP Top 10 for LLM Applications, S22 — OpenAI — agent approvals and security

1. Agent opens page
2. Page supplies adversarial text
3. Model interprets
4. Browser/app action is proposed
5. Policy blocks or confirms

CONTROL IMPLICATION

Browsing expands the untrusted context continuously.

Slide 109 — Context-File Injection

EVIDENCE STATUS: PROD

Sources: S18 — Hermes Agent documentation, S19 — Hermes Agent Security, S31 — OpenAI — AGENTS.md project instructions, S44 — Anthropic — Claude Code memory and CLAUDE.md

Concept	Meaning or control implication
Discovery	Where configured, an agent discovers and loads project instruction files
Risk	A cloned repository may author instructions that influence tool use
Control	Inspect, scope and sandbox untrusted projects before tool use

CONTROL IMPLICATION

As of 20 Aug 2026; loading rules are product- and configuration-specific.

Slide 110 — Tool-Output Injection

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

1. Agent calls tool
2. Tool returns attacker-controlled content
3. Content enters context
4. Planner changes course

CONTROL IMPLICATION

Tool output is data, not trusted policy.

Slide 111 — Memory-Based Instruction Persistence

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

1. Injection succeeds
2. Summary or fact is saved
3. Session ends
4. Memory reloads
5. Future behaviour changes

CONTROL IMPLICATION

Memory write policy and provenance are security controls.

Slide 112 — Jailbreak — Operational Definition

EVIDENCE STATUS: DEF

Sources: S11 — OWASP Top 10 for LLM Applications, S13 — MITRE ATLAS

Concept	Meaning or control implication
Objective	Bypass model or application behavioural restrictions
Method	Adversarial prompts, obfuscation or multi-turn pressure
Distinction	May not require changing a business task or calling a tool

Slide 113 — Jailbreak vs Prompt Injection

EVIDENCE STATUS: DEF

Sources: S11 — OWASP Top 10 for LLM Applications, S13 — MITRE ATLAS

Question	Jailbreak	Prompt injection
Target	Safety/behaviour restriction	Application instruction hierarchy
Typical carrier	User prompt	User or external content
Primary risk	Disallowed output	Changed task, disclosure or action

Slide 114 — Common Jailbreak Families — Course Synthesis

EVIDENCE STATUS: SYN

Sources: S13 — MITRE ATLAS

Concept	Meaning or control implication
Framing	Roleplay or fictional authority
Obfuscation	Encoding, spacing or substitution
Composition	Split intent across turns or modalities

Slide 115 — Why Model Guardrails Are Necessary but Insufficient

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile, S11 — OWASP Top 10 for LLM Applications, S22 — OpenAI — agent approvals and security

Concept	Meaning or control implication
Useful	Block known patterns and create alert signals
Fallible	Novel phrasing and modalities can evade classifiers
Hard boundary	Policy, schema, least privilege and approval limit effects

Slide 116 — Case — EchoLeak: Verified Vulnerability, Not a Confirmed Breach

EVIDENCE STATUS: CASE-V

Sources: S25 — Aim Labs, EchoLeak research disclosure, S40 — Microsoft — EchoLeak security context

1. Attacker-controlled content
2. Indirect prompt injection
3. Copilot context/data access
4. Exfiltration path
5. Vendor remediation

CONTROL IMPLICATION

Aim/Microsoft sources accessed 20 Aug 2026; verified vulnerability, not confirmed exploitation or a breach.

Slide 117 — Published GitHub MCP Prompt-Injection Demonstration

EVIDENCE STATUS: CASE-R

Sources: S26 — Invariant Labs, GitHub MCP prompt-injection research

1. Malicious repository content
2. Coding agent reads issue/context
3. MCP tools expose connected data
4. Unintended action/exfiltration path

CONTROL IMPLICATION

Researcher demonstration; source accessed 20 Aug 2026. Production exploitation is not established.

Slide 118 — Simulation — Employee Data Entered into Public GenAI

EVIDENCE STATUS: SIM

Sources: S09 — NIST AI 600-1, Generative AI Profile, S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

Concept	Meaning or control implication
Action	Employee pastes confidential data into an external service
Risk	Disclosure, retention and purpose may exceed policy
Control	Approved service, minimisation, DLP and user training

Slide 119 — Governance Case — Moffatt v Air Canada

EVIDENCE STATUS: CASE-V

Sources: S27 — Moffatt v Air Canada, 2024 BCCRT 149

1. Chatbot supplied incorrect information
2. Customer relied on response
3. Organisation disputed responsibility
4. Tribunal held organisation responsible

CONTROL IMPLICATION

Tribunal decision 2024 BCCRT 149; accessed 20 Aug 2026. Reliability/accountability case, not prompt injection or cyberattack.

Slide 120 — Incident, Demonstration, Evaluation, or Hypothetical?

EVIDENCE STATUS: SYN

Sources: S13 — MITRE ATLAS

Label	Evidence threshold	How to speak
Incident	Observed production event	State confirmed scope
Demonstration	Reproduced attack path	State tested environment
Evaluation	Controlled model/system test	Do not call it a breach
Simulation	Fictional teaching case	Label every number synthetic

Slide 121 — Activity 2 — Prompt-Injection Test

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Trace an indirect payload through a synthetic claims workflow
- Measure task success and attack success separately
- Select the earliest deterministic control that breaks the chain

Slide 122 — Activity 2 — Safe Harness and Test Boundaries

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Use only invented records
- Write to a local dummy log
- Block live email, shell, payment and production database tools

Slide 123 — Activity 2 — Establish a Clean Baseline

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Run legitimate tasks without hostile content
- Record expected output and permitted action
- Measure false blocks before adversarial changes

Slide 124 — Activity 2 — Test Controlled Variants

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Direct wording
- Indirect document or email wording
- Split and cross-modal variants

Slide 125 — Activity 2 — Add Hard Controls

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Restrict retrieval to the current case
- Validate recipients and tool parameters
- Require approval for sensitive disclosure or write action

Slide 126 — Activity 2 — Read ASR and False Positives Together

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026

Metric	Definition	Decision use
Attack success rate	Successful attacks / attempts	Residual adversarial exposure
False-positive rate	Blocked benign / benign tests	Business cost of guardrail
Clean-task success	Correct benign / benign tests	Utility under controls

Personal Data Across the AI Lifecycle

Map personal data wherever the system collects, derives, stores, transmits or logs it.

Slide 129 — The GenAI Data Lifecycle

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile, S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

1. Collect
2. Place in prompt/context
3. Process in selected model environment
4. Generate output
5. Log/retain/delete

CONTROL IMPLICATION

Purpose and protection duties apply across the lifecycle, not only at initial collection.

Slide 130 — An Agent Can Add New Data Surfaces

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S32 — OpenAI — ChatGPT Work overview

Concept	Meaning or control implication
Observation	Screenshots, browser state and external content
Action	Tool arguments, recipients and transaction details
Persistence	Memory, traces and scheduled-job state

Slide 131 — Tokens Are Authorities, Not Just Strings

EVIDENCE STATUS: DEF

Sources: S17 — OpenClaw Gateway Security, S19 — Hermes Agent Security

Concept	Meaning or control implication
API key	Authorises service use and spend
OAuth token	Carries user-approved scopes to an app
Session credential	Represents an authenticated browser or gateway session

Slide 132 — Token-Leak Paths

EVIDENCE STATUS: DEF

Sources: S17 — OpenClaw Gateway Security, S19 — Hermes Agent Security, S20 — Anthropic — Claude Code sandboxing

Path	Example	Control
Context/log	Secret pasted or returned by tool	Redact and block
Environment	Process inherits broad variables	Minimal environment
Browser	Cookie-bearing session	Dedicated profile and logout
Repository	Credential file in workspace	Secret scanning and isolation

Slide 133 — Secret and Token Controls

EVIDENCE STATUS: DEF

Sources: S17 — OpenClaw Gateway Security, S19 — Hermes Agent Security

1. Issue narrow scope
2. Use short lifetime
3. Isolate from context
4. Monitor use
5. Rotate or revoke

CONTROL IMPLICATION

Never give the model authority that the containing process does not need.

Slide 134 — PDPA Obligations Relevant to AI

EVIDENCE STATUS: DEF

Sources: S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

Obligation	AI-system application
Notification / applicable basis	Document the legal basis or exception and notify purposes as required; consent is not universal
Purpose limitation	Use data only for appropriate notified purposes
Protection	Secure prompts, outputs, memory, tools and logs
Retention/transfer	Delete when no longer needed and protect overseas transfers
Accountability	Assign responsibility and policies

Slide 135 — Data-Breach Notification Decision

EVIDENCE STATUS: DEF

Sources: S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA, S16 — PDPC Guide on Managing and Notifying Data Breaches

1. Contain and assess
2. Significant harm likely?
3. 500 or more affected?
4. Determine notifiability
5. PDPC within 3 calendar days after determination

CONTROL IMPLICATION

Notify the PDPC if significant harm is likely OR the breach is of significant scale; notify affected individuals as soon as practicable where required.

Slide 136 — Purpose Limitation and Data Minimisation

EVIDENCE STATUS: DEF

Sources: S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

First view	Second view
Over-collection	Bounded design
Whole mailbox or drive	Task-specific folders/fields
Full identifiers in prompts	Tokenise or remove identifiers
Indefinite memory	Purpose-linked retention

Slide 137 — Vendors, Subprocessors, and Overseas Transfers

EVIDENCE STATUS: DEF

Sources: S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

Concept	Meaning or control implication
Data path	Where prompts, files, outputs and logs travel
Contract	Use, retention, deletion, subprocessors and incident support
Assurance	Comparable protection for overseas transfers

Slide 138 — Logs, Retention, and Deletion

EVIDENCE STATUS: SYN

Sources: S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

Need	Keep	Limit
Security	Identity, policy result, tool call and outcome	Raw personal content where unnecessary
Audit	Decision and approval evidence	Unlimited conversational history
Operations	Failure traces for defined period	Orphaned memories after decommission

Slide 139 — Privacy by Design for Agents

EVIDENCE STATUS: SYN

Sources: S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026), S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

Concept	Meaning or control implication
Separate	Dedicated identities, stores and runtime boundaries
Minimise	Only required fields enter model context
Control	Validate recipients and require review for sensitive disclosure

Slide 140 — Fictional Case — Singapore Claims Assistant Leak

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

1. Injected claim document
2. Assistant retrieves unrelated records
3. Tool prepares external transmission
4. Egress/approval gap
5. PDPA assessment

CONTROL IMPLICATION

All names, counts, systems and outcomes are fictional.

Slide 141 — Data-Leakage Mitigation Playbook

EVIDENCE STATUS: SYN

Sources: S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA, S16 — PDPC Guide on Managing and Notifying Data Breaches

1. Detect
2. Contain
3. Revoke
4. Preserve evidence
5. Assess
6. Notify
7. Remediate

Slide 142 — Evidence Exercise — Build the Agent Data Inventory

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- List each field and whether it is personal data
- Name collection source, purpose, recipient and storage
- Set access, retention, deletion and breach owner

Frameworks Before Incident Analysis

Use each framework for the question it was designed to answer.

Slide 145 — The Framework Stack — Different Instruments

EVIDENCE STATUS: DEF

Sources: S10 — NIST AI Risk Management Framework, S11 — OWASP Top 10 for LLM Applications, S12 — OWASP Top 10 for Agentic Applications 2026, S13 — MITRE ATLAS, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026), S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

Instrument	Primary question	Use
NIST AI RMF	How do we manage risk?	Lifecycle
OWASP	What can go wrong?	Risk / vulnerability taxonomy
MITRE ATLAS	How do adversaries operate?	Techniques
IMDA	How do we bound and govern agents?	Accountability
PDPA	What duties apply to personal data?	Legal obligation

Slide 146 — NIST AI RMF — Govern, Map, Measure, Manage

EVIDENCE STATUS: DEF

Sources: S10 — NIST AI Risk Management Framework

1. Govern
2. Map
3. Measure
4. Manage

CONTROL IMPLICATION

The functions are iterative; governance is cross-cutting rather than a final sign-off.

Slide 147 — OWASP LLM and Agentic Top 10

EVIDENCE STATUS: DEF

Sources: S11 — OWASP Top 10 for LLM Applications, S12 — OWASP Top 10 for Agentic Applications 2026

First view	Second view
LLM application	Agentic application
Prompt, data, model and output risks	Goals, tools, identity, memory and coordination
Useful for GenAI/RAG applications	Useful when systems plan and act

Slide 148 — MITRE ATLAS

EVIDENCE STATUS: DEF

Sources: S13 — MITRE ATLAS

Concept	Meaning or control implication
Knowledge base	Tactics and techniques against AI-enabled systems
Coverage	Maps tactics, techniques, mitigations and documented case studies
Use	Threat assessment, red teaming and detection design

Slide 149 — IMDA Agentic AI Governance Framework — Four Dimensions

EVIDENCE STATUS: DEF

Sources: S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Concept	Meaning or control implication
Assess and bound	Choose suitable use cases; limit action space, data, tools and autonomy
Human accountability	Define significant checkpoints and meaningful approval
Technical controls	Apply controls and processes across the lifecycle
End-user responsibility	Enable informed use through transparency and training

CONTROL IMPLICATION

Action space and autonomy are distinct; some use cases may be unsuitable for agents.

Slide 150 — PDPA and PDPC Guidance

EVIDENCE STATUS: DEF

Sources: S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA, S16 — PDPC Guide on Managing and Notifying Data Breaches

Duty	Security implication
Purpose/notification	Document why data enters the system
Protection	Secure every prompt, memory, output and tool path
Retention/transfer	Control duration and overseas handling
Breach notification	Assess and notify when statutory tests are met

CONTROL IMPLICATION

Use enacted PDPA obligations and published PDPC guidance. The 2 Jun 2026 GenAI document is a public-consultation proposal, not final guidance.

Slide 151 — Positive Governance Case — Dayos Tiered IT Actions

EVIDENCE STATUS: CASE-V

Sources: S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Tier	Documented pattern	Control lesson
Tier 1	Low severity and reversible; propose-confirm with requesting user; no human engineer	Record reasoning/confidence; audit a cross-section biweekly
Tier 2	Agent diagnoses and proposes; human approval is required	Place approval before the effect
Tier 3	High severity and limited reversibility	Agent cannot perform the action

CONTROL IMPLICATION

IMDA-contributed case study, not an independent security endorsement; accessed 20 Aug 2026.

Slide 152 — OpenClaw Threat Walkthrough

EVIDENCE STATUS: PROD

Sources: S17 — OpenClaw Gateway Security

Boundary	Documented fact	Security decision
Trust	One trusted operator per gateway	Separate mixed-trust users
Tools	High-impact control-plane/node tools exist	Deny by default for untrusted content
State	Runtime directory contains sensitive material	Protect host and file permissions

CONTROL IMPLICATION

As of 20 Aug 2026; this is a configuration walkthrough, not a universal risk rating.

Slide 153 — Hermes Threat Walkthrough

EVIDENCE STATUS: PROD

Sources: S18 — Hermes Agent documentation, S19 — Hermes Agent Security

Boundary	Documented fact	Security decision
Execution	Local and isolated backends are available	Choose backend by risk
Context	Project files and skills can shape behaviour	Scan and review
Tools	Approvals and filters provide layers	Keep high-risk tools disabled unless needed

CONTROL IMPLICATION

As of 20 Aug 2026; selected backend, approvals and tool configuration determine exposure.

When AI Can Act: Agentic Threats

Map each threat to a component, authority path and earliest control point.

Slide 155 — OWASP Agentic Top 10 — System View

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

Component	Representative risks
Goal/planner	Goal hijack, rogue behaviour
Tools/identity	Tool misuse, privilege abuse, code execution
State/comms	Memory poisoning, insecure inter-agent communication
System/human	Supply chain, cascades, trust exploitation

Slide 156 — ASI01 — Agent Goal Hijack

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

1. Hostile content
2. Objective shifts
3. Planner selects attacker-serving steps
4. Tools execute

CONTROL IMPLICATION

Bind goals and validate actions independently of the model's stated rationale.

Slide 157 — ASI02 — Tool Misuse

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

Concept	Meaning or control implication
Legitimate tool	Tool itself may work as designed
Harmful use	Parameters, sequence or context creates harm
Control	Allowlist, schema, policy and approval

Slide 158 — ASI03 — Identity and Privilege Abuse

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

1. Agent receives identity
2. Scope exceeds task
3. Compromised plan invokes privilege
4. Action is attributed poorly

CONTROL IMPLICATION

Use a distinct agent identity with task-specific, short-lived permissions.

Slide 159 — ASI04 — Agentic Supply-Chain Vulnerabilities

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

Concept	Meaning or control implication
Components	Models, skills, plugins, MCP, packages and prompts
Change	Runtime discovery and updates can alter reviewed behaviour
Control	Provenance, pinning, integrity, isolation and inventory

Slide 160 — ASI05 — Unexpected Code Execution

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

Path	Exposure	Boundary
Generated code	Unsafe program is proposed	Review and test
Interpreter/shell	Code is executed	Sandbox and allowlist
Host escape	Runtime boundary fails	Hardened isolation and monitoring

Slide 161 — ASI06 — Memory and Context Poisoning

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

1. Attacker supplies content
2. Agent writes memory
3. Provenance is lost
4. Later session retrieves
5. Behaviour persists

CONTROL IMPLICATION

Gate memory writes and retain source, author, timestamp and review status.

Slide 162 — ASI07 — Insecure Inter-Agent Communication

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

Concept	Meaning or control implication
Identity	Can the receiver authenticate the sender?
Message	Is task intent and data integrity protected?
Delegation	Does authority narrow across handoffs?

Slide 163 — ASI08 — Cascading Failures

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

1. Wrong signal
2. Automated acceptance
3. Downstream transformation
4. Repeated propagation
5. System impact

CONTROL IMPLICATION

Validate at handoff boundaries and set fan-out, retry and budget limits.

Slide 164 — ASI09 — Human-Agent Trust Exploitation

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Concept	Meaning or control implication
Presentation	Confident explanation appears authoritative
Human factor	Time pressure and automation bias weaken review
Control	Show evidence and exact effect; audit approval quality

Slide 165 — ASI10 — Rogue Agents

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026

First view	Second view
Supported statement	Unsupported leap
OWASP identifies rogue-agent risk	An evaluation is a production breach
Evaluations may test concealment or misalignment	A model finding proves every deployment behaves alike

Slide 166 — Malicious or Untrusted Skills

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S18 — Hermes Agent documentation, S19 — Hermes Agent Security

Concept	Meaning or control implication
Instructions	A skill can steer tool selection and behaviour
Code	Bundled scripts can execute with host authority
Control	Review source, content, version, capabilities and updates

Slide 167 — CASE-R — ClawHavoc Reported Malicious-Skill Campaign

EVIDENCE STATUS: CASE-R

Sources: S37 — Koi Security — ClawHavoc reported malicious-skill campaign

1. Public skill marketplace
2. Skill content or setup lure
3. User/agent installs
4. Credential theft or malware path
5. Researcher reports snapshot

CONTROL IMPLICATION

Koi, 1 Feb 2026; accessed 20 Aug 2026: 341 of 2,857 skills in its audited snapshot, including 335 linked to one campaign; not a current ecosystem rate or affected-user count.

Slide 168 — CASE-V — Amazon Q Developer Extension 1.84.0

EVIDENCE STATUS: CASE-V

Sources: S38 — AWS Security Bulletin AWS-2025-015

1. Inappropriately scoped GitHub token
2. Malicious code committed
3. Release automatically included it
4. Code distributed but syntax error prevented execution
5. 1.84.0 withdrawn; 1.85.0 released

CONTROL IMPLICATION

AWS bulletin published 23 Jul 2025, updated 25 Jul 2025; distribution is not proof of execution or customer compromise.

Slide 169 — CASE-V — Replit Agent and an Application Database

EVIDENCE STATUS: CASE-V

Sources: S39 — Replit — application database incident and remediation

1. Agent had write authority
2. Application database data was deleted
3. Incident was detected
4. Database was fully restored
5. Default dev/prod separation was added

CONTROL IMPLICATION

Replit first-party post published 29 Jul 2025; it says no data was lost. Do not describe a permanent loss, customer breach or primary company database.

Slide 170 — Network Exposure

EVIDENCE STATUS: DEF

Sources: S17 — OpenClaw Gateway Security, S19 — Hermes Agent Security

Surface	Question	Control
Listener/gateway	Who can reach it?	Bind, authenticate, segment
Messaging channel	Who can trigger tools?	Pair and allowlist
Outbound web/API	Where can data go?	Proxy and destination allowlist

Slide 171 — Egress, Code Execution, and Host Impact

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S17 — OpenClaw Gateway Security, S19 — Hermes Agent Security

First view	Second view
Compromise without hard boundaries	Contained design
Broad network	Destination allowlist
User-level shell	Non-root sandbox
Long-lived credentials	Short-lived scoped credentials

Slide 172 — Where Scheduling Is Enabled

EVIDENCE STATUS: DEF

Sources: S17 — OpenClaw Gateway Security, S18 — Hermes Agent documentation, S34 — Prime Intellect — Prime Agent repository and launch documentation

1. Authorised user or scheduling tool creates task
2. Task persists
3. Credentials remain usable
4. Future action executes

CONTROL IMPLICATION

Inventory schedules, require approval, cap lifetime and provide revocation.

Slide 173 — Activity 3 — Framework Stack

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Use a fictional clinic assistant plus billing agent
- Match each decision question to a framework
- Avoid claiming that any one framework is complete

Slide 174 — Activity 3 — Threat and Metric Map

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Map an OWASP risk to an ATLAS technique only where direct evidence supports it; otherwise record no direct mapping
- Map controls to NIST/IMDA lifecycle evidence
- Attach PDPA duties where personal data is involved

Slide 175 — Activity 3 — Go-Live Gate

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Define clean-task and adversarial tests
- Name the accountable risk owner
- Set conditions for go, conditional go or no-go

Slide 176 — Activity 4 — Case Review

EVIDENCE STATUS: SYN

Sources: S25 — Aim Labs, EchoLeak research disclosure, S40 — Microsoft — EchoLeak security context, S38 — AWS Security Bulletin AWS-2025-015, S39 — Replit — application database incident and remediation, S37 — Koi Security — ClawHavoc reported malicious-skill campaign

- EchoLeak: CASE-V verified vulnerability, not confirmed breach
- Amazon Q extension and Replit database event: CASE-V first-party accounts
- ClawHavoc: CASE-R research snapshot with denominator and limitations

Slide 177 — Activity 4 — Kill Chain and Supply Gate

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Reconstruct delivery through impact
- Find the earliest effective break point
- Apply provenance, integrity, capability, isolation, approval and operations gates

From Threats to an Operating Control System

Controls must prevent, detect, respond and leave evidence.

Slide 180 — Defence in Depth for GenAI and Agents

EVIDENCE STATUS: SYN

Sources: S10 — NIST AI Risk Management Framework, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Concept	Meaning or control implication
Prevent	Bound inputs, identities, tools and runtime
Detect	Observe sequences, policy results and anomalies
Respond	Stop, revoke, preserve, recover
Govern	Own risk, test change and review evidence

Slide 181 — Step 1 — Inventory and Risk-Tier the Use Case

EVIDENCE STATUS: SYN

Sources: S10 — NIST AI Risk Management Framework, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Name owner
2. State purpose
3. List data/components
4. Classify impact
5. Assign tier

Slide 182 — Step 2 — Bound Data, Tools, and Autonomy

EVIDENCE STATUS: DEF

Sources: S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Concept	Meaning or control implication
Data	Allowed sources, fields and retention
Tools	Allowed operations and parameter ranges
Autonomy	Stop conditions, budgets and approval points

Slide 183 — Step 3 — Give Every Agent a Scoped Identity

EVIDENCE STATUS: DEF

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Create distinct identity
2. Grant minimum scope
3. Use short lifetime
4. Log use
5. Revoke on stop/change

Slide 184 — Step 4 — Guardrails and Schema Validation

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S11 — OWASP Top 10 for LLM Applications

1. Screen input
2. Generate/plan
3. Validate structured parameters
4. Apply policy
5. Screen output

CONTROL IMPLICATION

Model-based filters add friction; deterministic checks bound actions.

Slide 185 — Step 5 — Sandbox Code and Files

EVIDENCE STATUS: SYN

Sources: S17 — OpenClaw Gateway Security, S19 — Hermes Agent Security, S20 — Anthropic — Claude Code sandboxing, S21 — OpenAI — Codex sandboxing

Concept	Meaning or control implication
Process	For containerised workloads, prefer non-root and no-new-privileges where supported
Filesystem	Workspace-only or read-only mounts
Resources	CPU, memory, time and process limits

Slide 186 — Step 6 — Control Network Egress

EVIDENCE STATUS: SYN

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S30 — OpenAI — Codex cloud internet access

1. Default deny
2. Allow named destinations
3. Bind destination secrets
4. Inspect payload
5. Alert exceptions

Slide 187 — Step 7 — Deterministic Human Approval

EVIDENCE STATUS: DEF

Sources: S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Policy detects risk
2. Prepare exact action
3. Show effect and evidence
4. Approve once or reject
5. Execute or stop

Slide 188 — Make Human Approval Meaningful

EVIDENCE STATUS: DEF

Sources: S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

First view	Second view
Weak approval	Meaningful approval
Vague 'continue?'	Exact recipient/data/value
Standing permission	One action with expiry
No outcome review	Rejection and override audited

Slide 189 — Step 8 — Log the Decision and the Action

EVIDENCE STATUS: SYN

Sources: S10 — NIST AI Risk Management Framework, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Evidence	Why keep it
Trace and identity	Attribute one end-to-end run
Inputs/source provenance	Explain what influenced the model
Policy and approval	Prove control outcome
Tool arguments/result	Reconstruct actual effect

Slide 190 — Step 9 — Monitor Sequences, Not Only Events

EVIDENCE STATUS: SYN

Sources: S12 — OWASP Top 10 for Agentic Applications 2026, S13 — MITRE ATLAS

Concept	Meaning or control implication
Sequence	Unexpected tool order or fan-out
Boundary	Repeated denials, scope errors or new destinations
Consumption	Runaway turns, time, tokens or spend

Slide 191 — Step 10 — Red-Team Before Go-Live

EVIDENCE STATUS: DEF

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Test family	Evidence
Clean tasks	Utility and false blocks
Injection/jailbreak	Attack success by family
Tools/identity	Unsafe or denied action attempts
Memory/supply chain	Persistence and provenance controls
Recovery	Kill switch, revoke and restore

Slide 192 — A Measurable Go-Live Gate

EVIDENCE STATUS: SYN

Sources: S10 — NIST AI Risk Management Framework, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

Concept	Meaning or control implication
Performance	Task success on representative clean cases
Security	Attack and unsafe-action results by threat family
Operations	Approval quality, detection and recovery tests

CONTROL IMPLICATION

Thresholds are organisation-defined; do not invent universal percentages.

Slide 193 — Incident Response for an AI Agent

EVIDENCE STATUS: SYN

Sources: S13 — MITRE ATLAS, S16 — PDPC Guide on Managing and Notifying Data Breaches

Phase	Immediate action	Evidence or decision
Identify	Stop work and isolate the runtime	Affected goal, session, tools and data
Contain	Revoke credentials and block egress	Identity, scopes, destinations and timestamps
Assess	Preserve logs and determine impact	Personal data, actions, reversibility and notification test
Recover	Restore clean state and re-test controls	Root cause, corrective action, owner and approval

Slide 194 — Safe Change, Rollback, and Decommissioning

EVIDENCE STATUS: SYN

Sources: S10 — NIST AI Risk Management Framework, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026), S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

1. Inventory change
2. Re-test
3. Stage rollout
4. Rollback if gate fails
5. Revoke/delete/archive at retirement

Slide 195 — Shared Responsibility Across the Agent Lifecycle

EVIDENCE STATUS: SYN

Sources: S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026), S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

Role	Evidence owned
Provider	Limits, safety data, terms and change notice
Builder	Architecture, tools, provenance and tests
Deployer	Purpose, access, autonomy and approval
Operator	Monitoring, incident response and re-test
User/approver	Verification and escalation

Slide 196 — Responsible AI Principles Become Controls

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026), S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

Principle	Observable control
Accountability	Named owner and residual-risk sign-off
Transparency	Capability, data and appeal notice
Fairness	Segment testing and remediation
Privacy	Minimisation, purpose and retention
Human agency	Meaningful review and remedy

Slide 197 — Activity 5 — Governance Deployment Gate

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Review a fictional bank collections agent
- Use only synthetic segment and test data
- Decide go, conditional go or no-go

Slide 198 — Activity 5 — Bias, Privacy, and Autonomy Evidence

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Compare performance by affected group
- Map personal-data purpose and disclosure
- Set read, recommend, prepare and execute boundaries

Slide 199 — Activity 5 — Go, Conditional Go, or No-Go

EVIDENCE STATUS: SIM

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- State evidence and uncertainty
- Name conditions, accountable owner and review date
- Define kill switch, rollback and escalation

Slide 200 — Production Security Checklist

EVIDENCE STATUS: SYN

Sources: S10 — NIST AI Risk Management Framework, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026), S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

Gate	Minimum evidence
Own	Purpose, tier and accountable roles
Bound	Data, identity, tools, network and autonomy
Assure	Clean/adversarial tests and approval quality
Operate	Logs, alerts, response and rollback
Sustain	Change control and decommissioning

Slide 201 — Course Synthesis — Bound the Authority

EVIDENCE STATUS: SYN

Sources: S09 — NIST AI 600-1, Generative AI Profile, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)

1. Know the operating layers
2. Assume content can be hostile
3. Limit identity and tools
4. Gate irreversible effects
5. Preserve evidence

Slide 202 — Day 2 Recap — From Attack to Assurance

EVIDENCE STATUS: SYN

Sources: S10 — NIST AI Risk Management Framework, S12 — OWASP Top 10 for Agentic Applications 2026, S14 — IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026), S15 — PDPC Advisory Guidelines on Key Concepts in the PDPA

Concept	Meaning or control implication
Attack	Trace content through authority to effect
Defend	Use layered, deterministic boundaries
Govern	Measure, own and improve residual risk

Slide 203 — Assessment Reminder

EVIDENCE STATUS: ADMIN

Administrative or classroom-synthesis slide; no external factual claim is introduced.

- Complete required digital attendance
- Use slides, Learner Guide and activity evidence
- Submit the required assessment files on the LMS

Slide 204 — Assessment Flow

EVIDENCE STATUS: ADMIN

Administrative or classroom-synthesis slide; no external factual claim is introduced.

1. TRAQOM
2. Assessment attendance
3. WA then case study
4. Submit on LMS
5. Sign summary record

Detailed Activity Walkthroughs

SAFE-LAB BOUNDARY

Use synthetic data, dummy credentials, local or sandboxed tools, and non-routable recipients. Do not probe production services, install unreviewed community packages, or paste real personal data into public AI systems.

Activity 1 — Threat Modelling a Generative AI Concierge

Field	Value
Duration	45 minutes
Folder	activities/activity-1-threat-modelling-genai-concierge/
Evidence status	SIM — every organisation, person, event, count and value is fictional.

Step-by-step procedure

1. Read the scenario and list every channel, data store, retrieval source, model, tool and output consumer.
2. Draw the data-flow diagram. Mark where data crosses from a public, partner or internal writer into model context.
3. Mark personal data, secrets and business-sensitive data; record purpose, owner and retention for each.
4. For each attacker-writable source, write one realistic abuse case without running it against a live system.
5. Trace the authority path from content to model interpretation, tool selection, identity, action and effect.
6. Rank each boundary by impact, likelihood, reversibility and detection difficulty.
7. Choose the earliest deterministic control for the top three risks; state residual risk and operational cost.
8. Recommend proceed, conditional proceed or halt, and attach the completed deployment checklist.

Required evidence

- One labelled data-flow diagram
- One ranked abuse-case table
- Three control decisions with owners
- A rollout decision and checklist

ACCEPTANCE CRITERIA

The diagram covers at least three channels, four retrieval sources and four tools; each of the top three risks has a source-to-sink chain, owner, control, test evidence, residual risk and operational cost; the group records one rollout decision.

Activity 2 — Prompt Injection and the PDPA Breach Decision

Field	Value
Duration	60 minutes
Folder	activities/activity-2-prompt-injection-data-leakage/
Evidence status	SIM — use only the supplied masked data, local dummy tools and non-routable destinations.

Step-by-step procedure

1. Establish a clean baseline using a legitimate document and record expected output and permitted actions.
2. Run the supplied direct-injection variant against the dummy harness; record whether intent or output changes.
3. Run the indirect document/email variant and identify the exact carrier, trigger, interpreted instruction and proposed effect.
4. Run the context-file and cross-modal variants only with the supplied synthetic files; never upload real customer data.
5. Record attack success separately from refusal, false-positive and clean-task success rates.
6. Replace prompt-only protection with structural controls: trusted recipient binding, tool schema validation, retrieval isolation and action approval.
7. Re-run the same variant set and compare evidence, including useful-task degradation and operational friction.
8. Apply the current PDPA significant-harm and significant-scale decision tests; document facts still needed and do not assume every leak is notifiable.
9. Recommend a reduced-mode, conditional or halted posture and name the evidence needed to restore capability.

Required evidence

- Baseline and variant test log
- Source-to-sink chain
- ASR/false-positive/clean-task comparison
- PDPA decision record
- Prioritised remediation plan

ACCEPTANCE CRITERIA

The clean baseline and every supplied synthetic variant are logged against the same deterministic policy; attack success, false positives and clean-task success are reported separately; the PDPA record separates significant harm, significant scale, information gaps and the resulting decision.

Activity 3 — Selecting a Security Framework for GenAI and Agents

Field	Value
Duration	60 minutes
Folder	activities/activity-3-security-framework-selection/
Evidence status	SIM — all deployment details and performance data are fictional classroom material.

Step-by-step procedure

1. Classify NIST AI RMF, OWASP LLM Top 10, OWASP Agentic Top 10, MITRE ATLAS, IMDA and PDPA by the question each answers.
2. Separate the generative component from the acting component and record their data, tools, identity, state and autonomy.
3. Map threats to OWASP categories and ATLAS techniques without claiming the taxonomies are controls.
4. Map lifecycle actions to Govern, Map, Measure and Manage; name an owner and evidence artifact for each.
5. Map higher-impact or irreversible actions to IMDA-aligned autonomy limits and meaningful human approval.
6. Apply PDPA obligations where personal data is collected, used, disclosed, retained, transferred or breached.
7. Interpret attack success, false positives, clean-task success and segment results together; show calculation assumptions.
8. Define organisation-specific go-live thresholds, re-test triggers and a conditional go/no-go decision.

Required evidence

- Framework-purpose matrix
- Component-threat-control map
- Metric calculations
- Go-live gate with owners and re-test triggers

ACCEPTANCE CRITERIA

Each framework question is answered correctly; both operating layers are mapped; every go-live condition has a metric, organisation-defined threshold, owner, test method and re-test trigger rather than being presented as a universal fact.

Activity 4 — Evidence-Based Rogue Agent Incident Review

Field	Value
Duration	60 minutes
Folder	activities/activity-4-rogue-agent-incident-review/
Evidence status	CASE-V and CASE-R — preserve the label, source date and stated limitations for every case.

Step-by-step procedure

1. Choose EchoLeak, the Amazon Q extension event, the Replit application-database incident or the reported ClawHavoc campaign.
2. Record the source, publication date, evidence class and exact supported claim before analysis.
3. Separate normal capability, vulnerability or control failure, and observed impact.
4. Map the untrusted source, interpretation mechanism, identity or permission, privileged sink and effect.
5. For skills, plugins and MCP servers, review provenance, publisher, version, update channel, requested capabilities and bundled code.
6. Choose one preventive and one detective or recovery control at the earliest feasible chain point.
7. Define the approval screen: exact action, target, data, scope, destination, reversibility and evidence shown to the reviewer.
8. Present the reconstruction without converting research demonstrations into production breaches or reported counts into current prevalence.

Required evidence

- Evidence card for each case
- Source-to-sink chain
- Skill/plugin/MCP supply-chain review
- Preventive and recovery controls
- Residual-risk statement

ACCEPTANCE CRITERIA

Each of the four cases has a source, date, evidence label, source-to-sink chain, supported and unsupported claim, preventive control, detective or recovery control and residual risk; the Amazon Q code is stated as not executed, Replit as restored with no data loss, and campaign figures retain their dated-method limitations; one skill, plugin or MCP server receives an explicit gate decision.

Activity 5 — Agent Governance and the Deployment Gate

Field	Value
Duration	25 minutes
Folder	activities/activity-5-agent-governance-deployment-gate/
Evidence status	SIM — the bank, customers, metrics, volumes and outcomes are fictional.

Step-by-step procedure

1. Read aggregate and segment results; identify what the aggregate hides and verify every calculation.
2. Map personal-data purpose, notification, protection, retention, transfer and breach-response obligations.
3. Classify each action as agent-alone, human approval required or prohibited, based on impact and reversibility.
4. For every approval, specify the exact action, target, data, destination, evidence and rollback shown to the reviewer.
5. Confirm guardrails, identity scopes, sandbox, egress, memory provenance, logging, monitoring, kill switch and recovery evidence.
6. State go, conditional go or no-go; name accountable owner, unmet conditions, review date and release evidence.
7. Describe the user notice, challenge route, human escalation and remedy for an affected person.

Required evidence

- Segment-risk interpretation
- Data and autonomy inventory
- Approval matrix
- Named accountable owner
- Testable deployment decision

ACCEPTANCE CRITERIA

All calculations are reproducible from the SIM data; all ten capabilities are classified; every irreversible or high-impact action is prohibited or behind deterministic approval; every condition has an owner, test, expiry or review date and re-test trigger; affected people have a human review and remedy route.

Operational Best-Practice Checklist

Gate	Minimum evidence before approval
Own	Named business owner, technical owner, risk owner and incident owner
Purpose	Documented intended use, excluded uses, affected people and appeal route
Data	Sources, writers, personal-data purpose, minimisation, retention, deletion and transfers
Content trust	Untrusted-content map, provenance, ingestion review and prompt-injection test set
Identity	Dedicated agent identity, least privilege, short-lived credentials and revocation path
Tools	Allowlisted tools, constrained schemas, parameter validation and bounded action scope
Runtime	Sandbox, filesystem boundary, resource quotas and no privilege escalation
Network	Default-deny egress, named destinations, inspection and exception alerts
Human approval	Exact effect, target, data and reversibility shown before high-impact action
Supply chain	Publisher, version pin, signature or checksum, capability review and update re-approval
Memory	Provenance, review status, retention, correction, deletion and poisoning tests
Measure	Clean-task success, attack success, false positives, unsafe actions and segment results
Operate	Traceable logs, monitoring, kill switch, credential revoke, rollback and recovery test
Change	Re-test on model, prompt, corpus, tool, skill, identity, runtime or policy change

Source Register

Access dates should be recorded by the trainer or course owner when the package is refreshed. Where a product page changes, the deployed version and configuration remain part of the evidence record.

ID	Source	URL
S01	Turing, Computing Machinery and Intelligence (1950)	https://academic.oup.com/mind/article/LIX/236/433/986238
S02	Dartmouth Summer Research Project on AI proposal	http://jmc.stanford.edu/articles/dartmouth/dartmouth.pdf
S03	NIST, Reflections on Artificial Intelligence in Engineering	https://tsapps.nist.gov/publication/get_pdf.cfm?pub_id=822351
S04	Krizhevsky et al., ImageNet Classification with Deep CNNs	https://papers.nips.cc/paper/4824-imagenet-classification-with-deep-convolutional-neural-networks
S05	Vaswani et al., Attention Is All You Need	https://arxiv.org/abs/1706.03762
S06	Brown et al., Language Models are Few-Shot Learners	https://arxiv.org/abs/2005.14165
S07	Ouyang et al., Training language models to follow instructions	https://arxiv.org/abs/2203.02155
S08	Stanford AI Index Report 2023	https://hai.stanford.edu/assets/files/hai_ai-index-report_2023.pdf
S09	NIST AI 600-1, Generative AI Profile	https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence
S10	NIST AI Risk Management Framework	https://www.nist.gov/itl/ai-risk-management-framework
S11	OWASP Top 10 for LLM Applications	https://genai.owasp.org/llm-top-10/
S12	OWASP Top 10 for Agentic Applications 2026	https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/
S13	MITRE ATLAS	https://atlas.mitre.org/
S14	IMDA Model AI Governance Framework for Agentic AI v1.5 (updated 5 Jun 2026)	https://www.imda.gov.sg/-/media/imda/files/about/emerging-tech-and-research/artificial-intelligence/mgf-for-agentic-ai.pdf
S15	PDPC Advisory Guidelines on Key Concepts in the PDPA	https://www.pdpc.gov.sg/guidelines-and-consultation/2020/03/advisory-guidelines-on-key-concepts-in-the-personal-data-protection-act
S16	PDPC Guide on Managing and Notifying Data Breaches	https://www.pdpc.gov.sg/help-and-resources/2021/05/guide-on-managing-and-notifying-data-breaches-under-the-pdpa
S17	OpenClaw Gateway Security	https://docs.openclaw.ai/gateway/security
S18	Hermes Agent documentation	https://hermes-agent.nousresearch.com/docs/
S19	Hermes Agent Security	https://hermes-agent.nousresearch.com/docs/user-guide/security/
S20	Anthropic — Claude Code sandboxing	https://www.anthropic.com/engineering/claude-code-sandboxing
S21	OpenAI — Codex sandboxing	https://learn.chatgpt.com/docs/sandboxing
S22	OpenAI — agent approvals and security	https://learn.chatgpt.com/docs/agent-approvals-security
S23	DeepSeek-V3 official repository and model card	https://github.com/deepseek-ai/DeepSeek-V3
S24	Model Context Protocol documentation	https://modelcontextprotocol.io/docs/getting-started/intro
S25	Aim Labs, EchoLeak research disclosure	https://www.aim.security/lp/aim-labs-echoleak-blogpost
S26	Invariant Labs, GitHub MCP prompt-injection research	https://invariantlabs.ai/blog/mcp-github-vulnerability
S27	Moffatt v Air Canada, 2024 BCCRT 149	https://www.canlii.org/en/bc/bccrt/doc/2024/2024bccrt149/2024bccrt149.html
S28	OpenAI — skills and plugins	https://learn.chatgpt.com/docs/skills-and-plugins
S29	Anthropic Model Context Protocol overview	https://docs.anthropic.com/en/docs/mcp-overview
S30	OpenAI — Codex cloud internet access	https://learn.chatgpt.com/docs/cloud/internet-access
S31	OpenAI — AGENTS.md project instructions	https://learn.chatgpt.com/docs/agent-configuration/agents-md
S32	OpenAI — ChatGPT Work overview	https://learn.chatgpt.com/docs/enterprise/chatgpt-work-overview
S34	Prime Intellect — Prime Agent repository and launch documentation	https://github.com/PrimeIntellect-ai/prime-agent

S35	QM — official repository and security policy	https://github.com/yc-software/qm/security
S36	DeepSeek Harness — official developer-preview repository	https://github.com/deepseek-ai/deepseek-harness
S37	Koi Security — ClawHavoc reported malicious-skill campaign	https://www.koi.ai/blog/clawhavoc-341-malicious-clawedbot-skills-found-by-the-bot-they-were-targeting
S38	AWS Security Bulletin AWS-2025-015	https://aws.amazon.com/security/security-bulletins/AWS-2025-015/
S39	Replit — application database incident and remediation	https://replit.com/blog/doubling-down-on-our-commitment-to-secure-vibe-coding
S40	Microsoft — EchoLeak security context	https://www.microsoft.com/en-us/security/security-insider/emerging-trends/ai-application-security-considerations-for-organizations
S41	MCP authorisation specification (2025-06-18)	https://modelcontextprotocol.io/specification/2025-06-18/basic/authorization
S42	PDPC proposed GenAI consultation text (2 Jun 2026)	https://files.app.optical.gov.sg/pdpc/production/assets/6bb79f5a-6f1c-484f-8ed0-91cb64c93abd.pdf
S43	Anthropic — Claude Code permission modes	https://code.claude.com/docs/en/permission-modes
S44	Anthropic — Claude Code memory and CLAUDE.md	https://code.claude.com/docs/en/memory
S45	QM — official repository README	https://github.com/yc-software/qm